

MÔ HÌNH DEVOPS VÀ KẾ HOẠCH VẬN HÀNH, BẢO MẬT

Hệ thống Quản lý và Số hóa Tài liệu Thư viện HCMUS (HCMUS-LDMS)

Thông tin tài liệu

Trường	Nội dung
Mã tài liệu	HCMUS-LDMS-DEVOPS
Chủ sở hữu	DevOps Lead — Nguyễn Tuấn Anh; Nguyễn Quang Thái
Người xem xét	Solution Architect, QA và Project Manager
Phiên bản	1.0 — 22/08/2026
Trạng thái	Runbook dự thảo; kiểm tra vận hành/bảo mật chưa chạy giữ Chưa xác minh
Phạm vi	Local và demo cloud của MVP; production/on-premise ngoài phạm vi

Mục lục

- 1. Mục đích và ranh giới
- Mô hình DevOps của nhóm
- 2. Inventory và quyền sở hữu
- 3. Kiểm soát bảo mật
- 4. Quản lý secrets và truy cập
- 5. Logging, monitoring và cảnh báo
- 6. Backup, restore và retention
- 7. Incident Response
- 8. Deploy, rollback và continuity
- 9. Security Verification Checklist
- 10. RACI và giới hạn sẵn sàng

1. Mục đích và ranh giới

Tài liệu mô tả cách cấu hình, theo dõi, sao lưu, phục hồi và phản ứng sự cố cho môi trường local/demo. Nó không phải chứng nhận production readiness. Các con số RPO/RTO dưới đây là mục tiêu demo cần kiểm chứng;

không phải SLA đã cam kết.

- Local: Docker Compose, PostgreSQL, MinIO, frontend/backend local.
- Demo cloud: Vercel, Render, Neon, Cloudflare R2 sau smoke test.
- Production/on-premise: cần threat model, capacity, compliance, cost, HA và phê duyệt riêng.

1.1. Mô hình DevOps của nhóm

DevOps kết nối phát triển, kiểm thử, chuyển giao và vận hành bằng một luồng phản hồi chung:

Lập kế hoạch → Phát triển → Tích hợp liên tục → Kiểm thử → Chuyển giao → Vận hành/giám sát → Phản hồi về backlog và rủi ro .

Giai đoạn	Công cụ/nguồn	Kết quả
Lập kế hoạch	Backlog, Kanban, Project Plan	Card có AC, owner, phụ thuộc và rủi ro
Phát triển	Git, nhánh task ngắn, review	Thay đổi nhỏ có thể kiểm thử
Tích hợp	GitHub Actions	Ruff/Pytest, frontend lint/build/test
Chuyển giao	Docker Compose; profile demo cloud	Bản dựng gắn commit và smoke result
Vận hành	Log, Prometheus/Grafana theo cấu hình local gần phát hành	Tín hiệu health/job/error/quota
Phản hồi	Defect, incident, metric, UAT	Backlog, Risk, ADR, Test/Quality cập nhật

Nhóm không tuyên bố có hạ tầng dưới dạng mã hoàn chỉnh hoặc giám sát 24/7 khi chưa có run evidence. Docker Compose là cấu hình môi trường hiện có; Kubernetes/Ansible chỉ là ví dụ lý thuyết trong **Final-Answer.md**, không phải công cụ nhóm đã dùng.

Ba profile được quản lý tách biệt: local phát triển, local gần phát hành và demo cloud. Không vận hành đồng thời nhiều phiên bản production trong baseline. Nếu cần giữ bản ổn định và bản thử nghiệm, nhóm dùng tag/build ID riêng, dữ liệu/secrets tách, triển khai demo sau phê duyệt và có đường rollback về bản ổn định.

2. Inventory và quyền sở hữu

Thành phần	Dữ liệu/chức năng	Owner	Mức nhạy cảm	Recovery source
Frontend React	UI, không chứa secret	Frontend Lead	Public code/config không bí mật	Git/build artifact
FastAPI backend	Auth, RBAC, business logic, job	Backend Lead	High	Git + config inventory
PostgreSQL	Account/role, metadata, state, text, job/audit	Backend/DevOps	High	Database backup
MinIO/R2	Source và EPUB private	DevOps	High	Object version/backup theo profile
OAuth/config	Client config/credential	DevOps	Critical secret	Secret manager/env, không Git
CI/CD/deploy	Build/deploy permission	DevOps	High	Platform config + documented runbook
Evidence store	Report/log/screenshot đã che bí mật	QA	Internal	Repository/artifact store được kiểm soát

Mỗi môi trường có inventory riêng gồm service URL, owner, account owner, region nếu áp dụng, quota, backup method và ngày rà soát. Không ghi secret value vào inventory.

3. Kiểm soát bảo mật

3.1. Authentication và session

- Local có thể dùng tài khoản mô phỏng tách khỏi dữ liệu thật; demo dùng OAuth khi cấu hình được kiểm chứng.
- Backend xác minh identity/session cho mọi endpoint protected.
- Cookie/token phải dùng thuộc tính và thời hạn phù hợp với cơ chế đã chọn; logout/revocation behavior được kiểm thử.
- Không log token, authorization header hoặc credential.

3.2. Authorization

- Quyền được kiểm tra server-side theo resource/action; UI chỉ hỗ trợ trải nghiệm.
- Role matrix tối thiểu: Reader, Editor/Librarian, Admin; quyền publish có thể tách nếu triển khai.
- Search, list, reader, metadata, job và object access đều lọc theo quyền.
- Bất kỳ bypass nào là defect High/Critical tùy phạm vi dữ liệu.

3.3. Data/object protection

- Bucket/object mặc định private; không dùng public listing.
- Backend cấp URL tạm thời sau authorization; TTL được cấu hình và kiểm thử expiry.
- Source không bị ghi đè; object key/version/hash liên kết document record.
- Upload kiểm tra loại/kích thước và không tin filename/content-type từ client một cách tuyệt đối.
- Dữ liệu thật chỉ vào hệ thống khi có owner và xác nhận quyền.

3.4. Application/dependency security

- Validate input và dùng query/ORM an toàn; escape/sanitize nội dung hiển thị theo context.
- Dependency/secret scan chạy khi công cụ có sẵn; kết quả phải được review, không chỉ tạo report.
- CORS, error response và debug mode được cấu hình theo môi trường.
- Không trả stack trace, object key nội bộ hoặc thông tin hạ tầng không cần thiết cho người dùng.

4. Quản lý secrets và truy cập

Quy tắc	Yêu cầu
Lưu trữ	Dùng environment/platform secret; <code>.env</code> local không commit
Quyền	Least privilege; chỉ owner/backup owner cần thiết
Phân tách	Credential local/demo khác nhau; không dùng credential cá nhân làm nguồn duy nhất
Rotation	Rotate khi lộ/ngghi ngờ, đổi thành viên hoặc theo chu kỳ nhóm chốt
Evidence	Chỉ ghi tên biến, thời gian rotate và người thực hiện; che value
Offboarding	Thu hồi quyền Git/platform/storage/database và rotate shared secret

Nếu secret xuất hiện trong Git/log/UI: thu hồi/rotate trước, sau đó mới làm sạch artifact và điều tra. Xóa chuỗi khỏi commit mới không làm secret cũ an toàn trở lại.

5. Logging, monitoring và cảnh báo

5.1. Event cần ghi

- Login success/failure ở mức không lộ credential.
- Upload, edit, publish, role/permission change.
- Job create/start/complete/fail/retry/recover.
- Access denied và object URL issuance ở mức metadata phù hợp.
- Deploy/rollback, migration và restore action.

Log tối thiểu: timestamp có timezone, environment, correlation/request ID, actor ID đã tối thiểu hóa, action, resource ID, outcome và error code. Không log password/token/nội dung tài liệu không cần thiết.

5.2. Tín hiệu theo dõi demo

Tín hiệu	Trigger điều tra	Hành động đầu
API unavailable/error tăng	Smoke fail hoặc lỗi lặp	Kiểm tra deploy/log/dependency, cân nhắc rollback
Job processing quá timeout	Job vượt timeout đã cấu hình	Mark/recover có kiểm soát, không retry vô hạn
Database/storage lỗi	Connection/object error lặp	Dừng thao tác ghi nguy cơ, kiểm tra quota/credential
Access denied bất thường	Nhiều deny hoặc resource nhạy cảm	Xác minh actor/session và phạm vi ảnh hưởng
Quota/cost gần giới hạn	Platform warning	Giảm demo load, archive hợp lệ hoặc dùng fallback local

Không tuyên bố 24/7 monitoring hoặc SLA vì baseline môn học không có đội trực vận hành.

6. Backup, restore và retention

6.1. Mục tiêu demo cần kiểm chứng

Nội dung	Mục tiêu kế hoạch	Trạng thái
Database RPO	Không quá 24 giờ đối với dữ liệu demo có giá trị	Chưa xác minh
Database/object RTO	Khôi phục luồng demo trong 4 giờ sau khi có người xử lý	Chưa xác minh
Source integrity	Không mất source đã xác nhận tiếp nhận	Chưa xác minh
Restore drill	Ít nhất một lần trước release decision	Chưa chạy

Các mục tiêu này có thể thay đổi sau PoC. Production cần RPO/RTO do owner nghiệp vụ phê duyệt.

6.2. Backup scope và quy trình

- Database: schema, metadata, state, corrected text, job/audit cần thiết.
- Object: source và EPUB cùng version/hash; backup phải giữ mapping với database.
- Config: danh sách biến/tên secret, migration, deploy/runbook; không sao chép secret plaintext vào tài liệu.
- Evidence: thời gian, phạm vi, tool/version, nơi lưu, checksum khi phù hợp và người thực hiện.

Restore drill phải dùng môi trường tách, phục hồi database + object mapping, chạy integrity check và smoke core flow. Một backup chưa restore thử không được coi là evidence phục hồi.

6.3. Retention và xóa

Loại	MVP	Quy tắc
Source có quyền	Giữ theo dataset approval	Không xóa nếu còn record phụ thuộc; có owner
File upload lỗi/orphan	Quarantine ngắn hạn	Xóa sau reconciliation và review
Log ứng dụng	Giữ đủ cho demo/điều tra trong baseline	Tối thiểu hóa dữ liệu nhạy cảm
Backup demo	Giữ theo vòng đời môn học/quyết định owner	Xóa có kiểm soát sau khi hết mục đích
PII	Chỉ giữ tối thiểu cần thiết	Không thu thập nếu không phục vụ yêu cầu

Không có retention production được phê duyệt trong baseline này.

7. Incident Response

7.1. Phân loại

Severity	Ví dụ	Mục tiêu phản ứng khi có người trực
SEV-1	Lộ/mất dữ liệu, credential active bị lộ, core unavailable trước UAT	Acknowledge sớm nhất; ưu tiên cô lập
SEV-2	Một chức năng Must/role bị hỏng, job hàng loạt lỗi	Triage trong ngày làm việc/học gần nhất
SEV-3	Lỗi cục bộ có workaround	Đưa defect backlog có owner

Mục tiêu trên không phải SLA 24/7.

7.2. Quy trình

1. **Detect/Record:** tạo Incident ID, thời gian, reporter, environment và triệu chứng.
2. **Contain:** khóa endpoint/account, revoke/rotate secret, dừng deploy/job hoặc cô lập dữ liệu khi cần.
3. **Assess:** xác định resource/actor/time window và dữ liệu ảnh hưởng; bảo toàn log.
4. **Eradicate/Recover:** sửa nguyên nhân, restore/rollback và xác minh bằng test.
5. **Communicate:** PM điều phối; owner nghiệp vụ/dữ liệu được thông báo khi có tác động.

6. **Review:** RCA, timeline, action owner/date, risk/ADR/test update.

Không xóa log/evidence để làm đẹp kết quả. Thông báo bên ngoài hoặc pháp lý phải do người có thẩm quyền quyết định.

8. Deploy, rollback và continuity

8.1. Trước deploy

- Build/commit xác định; config schema và migration được review.
- Test/gate theo Quality Plan đạt hoặc có ngoại lệ.
- Backup/checkpoint phù hợp trước thay đổi dữ liệu.
- Smoke plan, rollback owner và communication channel rõ.

8.2. Sau deploy

- Health, login, authorization, upload/job và reader smoke.
- Kiểm tra log không có secret/stack trace bất thường.
- Ghi deploy ID, environment, thời gian, người thực hiện và kết quả.

8.3. Rollback

Rollback khi health/core flow fail, migration gây lỗi dữ liệu hoặc security control không hoạt động. Rollback app không tự động rollback database; migration phải có kế hoạch tương thích/restore. Nếu cloud không ổn định, demo có thể chuyển local đã kiểm chứng và phải công bố rõ profile.

9. Security Verification Checklist

- [] Server-side authentication/authorization test đạt.
- [] Draft/private không xuất hiện trong search/list trái quyền.
- [] Bucket/object không truy cập ẩn danh; URL hết hạn hoạt động đúng.
- [] Không có secret trong Git, frontend bundle, report hoặc log.
- [] Upload validation và error handling đã kiểm thử.
- [] Source/version/hash còn nguyên sau failure/retry.
- [] Dependency findings Critical/High đã xử lý hoặc có ngoại lệ đúng thẩm quyền.
- [] Restore drill database + object mapping đạt.
- [] Log có correlation/outcome nhưng không lộ dữ liệu nhạy cảm.
- [] Incident/deploy/rollback contact và runbook mở được.

Các ô chưa chọn phản ánh chưa có record kiểm chứng, không phải tuyên bố kiểm soát đã thất bại.

10. RACI và giới hạn sẵn sàng

Hoạt động	R	A	C
Secrets/deploy/backup	DevOps Leads	Solution Architect	PM, QA
App/RBAC/object security	Backend Lead	Solution Architect	QA, DevOps
Security/recovery test	QA + DevOps	QA Lead	Backend
Incident coordination	Incident owner	PM	Nghiệp vụ/data owner
Production decision	Chưa thuộc MVP	Sponsor/owner có thẩm quyền	Nhóm kỹ thuật

Nguồn liên quan: [Architecture](#), [SRS](#), [Risk Register](#), [Quality Plan](#), [Test/UAT Plan](#), [SOW](#) và [Decision/ADR](#).